

[doc. web n. 9940565]
Provision of September 14, 2023
Register of Provisions
No. 404 of September 14, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Ginevra Cerrina Feroni, Vice President,
Dr. Agostino Ghiglia and Attorney Guido Scorza,
members, and Dr. Claudio Filippi, Deputy
Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of personal data, hereinafter "Code") as amended by Legislative Decree No. 101 of August 10, 2018, containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU) 2016/679";

HAVING REGARD TO the complaint submitted by Mr. XX on 09/20/2021, pursuant to Article 77 of the Regulation, in which a violation of the rules on the protection of personal data by Nimbus s.r.l. was reported;

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor's Regulation No. 1/2000;

REPORTING Prof. Ginevra Cerrina Feroni;

PREMISE

1. The initiation of the procedure.

With the complaint dated 09/20/2021, Mr. XX represented that, on 11/06/2019, he was hired by Nimbus s.r.l. under a fixed-term employment contract and that he performed his work activity at the headquarters located at Viale Coni Zugna No. 71, in Milan. The complaint stated that, at the workplace, there was a presence detection system based on the reading of fingerprints introduced without any information being provided or consent being requested in this regard.

With the note dated 10/27/2021 (prot. No. 53982), the Office made a request for information to the Company, pursuant to Article 157 of Legislative Decree 196/2003 (containing the Code regarding the protection of personal data, hereinafter "Code"), aimed at understanding the main characteristics of the biometric system, as well as the legitimacy of the processing and the specific purposes that made the use of the biometric detection system necessary.

The Company responded with a note dated 11/19/2021, in which it stated that:

- the presence detection system via fingerprints was activated on February 1, 2019;
- the company XX was responsible for the installation of the system in question, "ensuring that the methods of use of the device were fully compliant with the current regulations on the protection of personal data";
- the territorially competent Labor Inspectorate, with an email dated 11/10/2021, in response to a specific request from the Company, confirmed that the installation of the presence detection system, based on biometric recognition, does not require the authorization referred to in Article 4 of Law 300/1970.

Regarding the technical characteristics of the biometric system in use, the Company attached the technical report prepared by the installing company, which indicates that:

- "the device installed by the Company (...) is a time clock presence detector equipped with a biometric reader (fingerprints). By using the device, personnel can certify their entries/exits from the workplace through the provided methods, namely the fingerprint or, alternatively, a unique ID (numeric)

associated with each worker and the corresponding assigned password”;

- “The device is compliant with privacy protection regulations, as personal fingerprints are collected and stored exclusively in the internal memory of the device itself and are rendered effectively undecipherable/unusable in any other context, thanks to the particular algorithm with which they are encrypted. Furthermore, they are in fact not readable/exportable for different uses, given the inaccessibility of the internal memory of the device”;
- “The individual characteristics of the fingertip are vectorized into unique points and converted by the terminal into a complex numeric code, using a special algorithm. The corresponding employee number is therefore linked to this value.”

With a subsequent note dated 01/29/2022, the Company, in response to a request for additional information from the Office, specified that:

- its employees were provided with information, pursuant to Article 13 of the Regulation, stating that “Genetic or biometric data concerning them are not processed”; and this is because the iAccess device does not store images of the fingerprint in any case, processing only an anonymous and virtual reference model”;
- the Company operates in two locations and both have biometric presence detection systems, involving 13 employees;
- regarding the legitimacy of the processing, these “are not in the slightest in question, as, as already mentioned, there is no storage of biometric data and therefore there is no processing of the same”;
- “as for the purposes of the installation of the iAccess device, it was designed, created, and used for the detection of the...
the unique identification of that natural person”.

- “The presence in relation to the management of the employment relationship”;
- “The procedure for acquisition (enrolment) and the related registration in the user system, in the facility in question, (...) occurs through the terminal itself which, during the acquisition phase, is used as a reader in order to detect the sample associating it with an ID previously assigned to the user via the interface/management software along with the first and last name. It is reiterated that users can manage access and marking through that ID regardless of the use and detection of the biometric sample, which has in no case been imposed on them. Subsequently, the sample itself is stored, encrypted by a specific algorithm developed by the manufacturer and rendered effectively undecipherable/unusable in any other context other than recognition and presence marking, through the described device. (...) Furthermore, the device itself is interfaced via a LAN connection to a single dedicated workstation, excluded from the corporate network, protected by an access password, available to authorized personnel solely for downloading access/presence reports for corporate processing needs”;
- “The method of comparison of the biometric model at the time of detection is one-to-one”;
- “The raw data is deleted at the end of the access/clocking procedure, the sample (present exclusively and with the characteristics outlined above within the device, or in the form of an undecipherable/unusable algorithm externally) within 24 hours from the termination of the relationship, through the removal of the user ID and the related acquired data. It is reiterated that all data is stored exclusively in the device; the same, upon clocking, identifies the user, transmits to the dedicated workstation and the related management software the user ID and the times of entry and exit, without any other information.”

Based on the statements made by the Company, the Office proceeded to notify the company of the initiation of the sanctioning procedure, pursuant to Article 166, paragraph 5, of the Code in relation to the violation of Articles 5, paragraph 1, letter a), 6, 9, paragraph 2, letter b), and 13 of the Regulation (note of 14/04/2022, prot. no. 20869).

The Company sent, on 11/05/2022, its defense writings, pursuant to Article 18 of Law No. 689/1981, emphasizing its good faith in the treatment in question, having received precise guarantees from the installing company of the biometric detection system regarding the correctness of the treatment carried out. It was also represented that, on 30/04/2022, the “removal of the employee presence detection

devices via fingerprints was carried out, replacing in both local units the existing devices with badge detection systems, which do not absolutely detect biometric data; the pre-existing software was therefore removed and all data of the employees already stored was deleted."

On 01/02/2023, the hearing of the Company was held, pursuant to Article 18 of Law No. 689/1981, during which the Company reiterated its lack of culpability in the processing operations subject to contestation.

2. The outcome of the investigation.

As a result of the examination of the documentation produced and the statements made by the party during the proceedings, it is noted that, unless the fact constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code. It emerged that the company, as the data controller, has carried out a processing of personal data, relating to its employees, that does not comply with the regulations on the protection of personal data.

2.1. The processing of biometric data carried out by the Company. Violation of Article 9, paragraph 2, letter b), of the Regulation.

In substance, it emerged that the Company has carried out, starting from February 2019, a processing of personal data, relating to 13 employees, through a biometric detection system, installed at the two work units and aimed at recording attendance at work. In particular, this system was based on the detection of the fingerprint whose main characteristics were converted into a numerical code, associated with the employee. This system has been removed during the proceedings and replaced with a badge-based detection system (defensive measures of 11/05/2022).

The processing of personal data carried out by the Company has therefore concerned the biometric data of the employees, in light of the numerous interventions of the Authority which, with its own provisions, has clarified that this type of processing is configured both in the registration phase (so-called enrolment, consisting of the acquisition of the biometric characteristics - in this case fingerprints - of the data subject (see points 6.1 and 6.2 of Annex A to the Guarantor's provision of 12 November 2014, No. 513, at www.garanteprivacy.it, doc. web no. 3556992), and in the biometric recognition phase, at the time of attendance detection (see also point 6.3 of Annex A to the aforementioned provision).

On this point, it is necessary to recall the definition of biometric data provided by the Regulation, according to which they are "personal data obtained from a specific technical processing related to the physical, physiological or behavioral characteristics of a natural person that allow or confirm the unique identification of that natural person."

the unique identification, such as facial images or fingerprint data" (art. 4, no. 14, of the Regulation).

According to the regulations on personal data protection, the processing of biometric data (generally prohibited under art. 9, par. 1, of the Regulation) is allowed only if one of the conditions set out in art. 9, par. 2, of the same Regulation is met and, regarding processing carried out in the workplace, only when the processing is "necessary for fulfilling the obligations and exercising the specific rights of the data controller or the data subject in the field of labor law and social security and social protection, to the extent that it is authorized by Union law or the laws of the Member States or by a collective agreement under the laws of the Member States, in the presence of appropriate safeguards for the fundamental rights and interests of the data subject" (art. 9, par. 2, lett. b), of the Regulation; see also, art. 88, par. 1 and recitals 51-53 of the Regulation).

As has been clarified multiple times by the Authority, although in the workplace the purposes of monitoring employee attendance and verifying compliance with working hours may fall within the scope of art. 9, par. 2, lett. b) of the Regulation (as they involve processing that is "necessary for fulfilling the obligations and exercising the specific rights of the data controller or the data subject in the field of labor law [and social security and social protection]"), the processing of biometric data is allowed only "to the extent that it is authorized by Union law or the laws of the Member States [...] in the presence of appropriate safeguards for the fundamental rights and interests of the data subject"

(art. 9, par. 2, lett. b), and recitals 51-53 of the Regulation) (see most recently the Authority's decision no. 369 of 10/11/2022, web doc no. 9832838).

Therefore, for the processing of biometric data to be lawfully carried out, it is necessary that it finds its basis in a legal provision that meets the requirements set by data protection regulations, including in terms of the proportionality of the regulatory intervention concerning the purposes intended to be pursued.

Currently, there is no suitable legal basis that can meet the requirements set by the Regulation and the Code to legitimize the data controllers in carrying out the processing of biometric data for the purpose of monitoring employee attendance under art. 9, par. 2, lett. b) of the Regulation.

In light of the above, it is noted that the processing of biometric data carried out by the Company was conducted in the absence of a suitable legal basis, in violation of art. 9, par. 2, lett. b) of the Regulation.

2.2. Violation of arts. 5, par. 1, lett. a) and 13 of the Regulation.

According to the provision of art. 5, par. 1, lett. a), of the Regulation, the data controller must process data "lawfully, fairly, and transparently," where, with particular reference to the context of the employment relationship, the obligation to inform the employee is also an expression of the duty of fairness.

As a result of the investigation, it emerged that in the information notice prepared by the Company there was no reference to the processing of biometric data carried out for attendance monitoring, nor was there any indication of the possibility of using, as an alternative to the biometric system, the traditional badge-based system (unlike what was stated by the supplying company in the technical report attached to the note of 19/11/2021).

Such conduct is in contrast with what is prescribed by art. 13 of the Regulation, according to which the data controller must provide data subjects with information that presents the main characteristics of the processing they intend to carry out, indicating among other things the purposes and methods of processing, the legal basis, and the retention periods of the processed data.

For these reasons, it is noted that the company has carried out the processing of biometric data of employees in violation of arts. 5, par. 1, lett. a) and 13 of the Regulation, from the date of installation and activation of the devices, as documented, until the date of cessation which occurred on 30/04/2022.

3. Conclusions: declaration of unlawfulness of the processing. Corrective measures under art. 58, par. 2, Regulation.

For the aforementioned reasons, the Authority believes that the statements, documentation, and reconstructions provided by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation of the procedure and are therefore inadequate to allow for the closure of the present procedure, as none of the cases provided for by art. 11 of the Garante Regulation no. 1/2019 apply.

The processing of biometric data carried out by the company is unlawful, as, for the reasons stated above, it violates arts. 5, par. 1, lett. a), 9, par. 2, lett. b) and 13 of the Regulation.

Therefore, in light of the corrective powers granted by art. 58, par. 2 of the Regulation, an administrative pecuniary sanction is imposed pursuant to art. 83 of the Regulation, proportionate to the circumstances of the specific case (art. 58, par. 2, lett. i) Regulation).

4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58,

par. 2, lett. i), and 83 of the Regulation; art. 166, paragraph 7, of the Code.

The Authority, pursuant to art. 58, par. 2, lett. i) of the Regulation and art. 166 of the Code, has the power to impose an administrative monetary sanction provided for by art. 83, par. 5, of the Regulation,

through the adoption of an injunction order (art. 18, law of November 24, 1981, no. 689).

It is deemed necessary to apply paragraph 3 of art. 83 of the Regulation where it states that “If, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative monetary sanction shall not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same art. 83, par. 5.

With reference to the elements listed in art. 83, par. 2 of the Regulation for the purpose of applying the administrative monetary sanction and its quantification, considering that the sanction must “in any case [be] effective, proportionate and dissuasive” (art. 83, par. 1 of the Regulation), it is represented that, in this case, the following circumstances have been considered:

- in relation to the nature, gravity, and duration of the violation, it has been taken into account that the processing involved special categories of data and that it lasted for a period of about three years;
- in relation to the intentional or negligent nature of the violation and the degree of responsibility of the data controller, the conduct and degree of responsibility of the company related to the non-compliance with the general principles of processing have been considered;
- the absence of specific previous violations against the company related to breaches of personal data protection regulations;
- the cooperation provided during the investigation and, in particular, the prompt compliance with the Authority's indications.

It is also considered that the economic conditions of the offender are relevant in this case, determined based on the revenues achieved by the company with reference to the abbreviated financial statements for the year 2022, as well as the particular economic context related to the health emergency. Lastly, the amount of sanctions imposed in similar cases is taken into account.

In light of the above elements and the evaluations made, it is deemed appropriate, in this case, to impose on Nimbus s.r.l. an administrative sanction of payment of an amount equal to €5,000.00 (five thousand).

In this context, it is also deemed appropriate, considering the type of violations established that concerned the general principles of processing, that pursuant to art. 166, paragraph 7, of the Code and art. 16, paragraph 1, of the Regulation of the Authority no. 1/2019, the publication of this provision on the Authority's website should proceed.

It is also deemed that the conditions referred to in art. 17 of Regulation no. 1/2019 are met.

****ALL OF THE ABOVE CONSIDERED, THE AUTHORITY****

finds the unlawfulness of the processing carried out by Nimbus s.r.l., represented by the legal representative pro tempore, with registered office in Milan, Via Pisanello no. 21, C.F. 10508630968, pursuant to art. 143 of the Code, for the violation of arts. 5, par. 1, lett. a), 9, 13, of the Regulation;

****ORDERS****

pursuant to art. 58, par. 2, lett. i) of the Regulation for Nimbus s.r.l. to pay the sum of €5,000.00 (five thousand) as an administrative monetary sanction for the violations indicated in this provision;

****ENJOINS****

therefore the same Company to pay the aforementioned sum of €5,000.00 (five thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to art. 27 of law no. 689/1981. It is reminded that the offender retains the right to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction, within the term referred to in art. 10, paragraph 3, of legislative decree no. 150 of September 1, 2011, provided for the submission of the appeal as indicated below (art. 166, paragraph 8, of the Code);

****DISPOSES****

the publication of this provision on the Authority's website pursuant to art. 166, paragraph 7, of the Code and art. 16, paragraph 1, of the Regulation of the Authority no. 1/2019, and considers that the conditions referred to in art. 17 of Regulation no. 1/2019 are met.

Pursuant to art. 78 of the Regulation, as well as articles 152 of the Code and 10 of legislative decree no. 150/2011, against this provision an appeal may be filed with the ordinary judicial authority, with a

petition submitted to the ordinary court of the place identified in the same art. 10, within thirty days from the date of communication of this provision, or sixty days if the appellant resides abroad.

Rome, September 14, 2023

****THE VICE PRESIDENT****

Cerrina Feroni

****THE REPORTER****

Cerrina Feroni

****THE DEPUTY SECRETARY GENERAL ****

Filippi